



Cybersecurity Governance Guide for Regulated Organizations

Health Insurance Portability and Accountability Act (HIPAA)

Technical controls, regulatory frameworks, and continuous monitoring for cybersecurity governance under HIPAA requirements.

1. HIPAA Security Rule Framework

The HIPAA Security Rule (45 CFR Part 164 Subpart C) establishes the cybersecurity baseline for all covered entities and business associates handling ePHI:

- **Administrative Safeguards (164.308):** Security management process, assigned security responsibility, workforce security, information access management, security awareness training, security incident procedures, contingency plan, evaluation, and BA contracts.
- **Physical Safeguards (164.310):** Facility access controls, workstation use and security, device and media controls.
- **Technical Safeguards (164.312):** Access controls, audit controls, integrity controls, authentication, and transmission security.
- **Addressable vs. Required:** Some specifications are required and must be implemented. Others are addressable and may use equivalent measures that must be documented. Addressable does not mean optional.
- **OCR Enforcement:** HHS OCR enforces HIPAA through investigation and civil money penalties. OCR has levied penalties exceeding 1 million dollars for inadequate technical safeguards.

2. Required Technical Safeguards for ePHI

The HIPAA Security Rule technical safeguards translate to specific cybersecurity controls that OCR examiners verify:

- ✓ **Unique User Identification (Required):** Every user must have a unique login. No shared accounts for systems accessing ePHI.
- ✓ **Automatic Logoff (Addressable):** Workstations accessing ePHI must auto-lock after defined inactivity period.
- ✓ **Encryption of ePHI at Rest and in Transit (Addressable but effectively required):** OCR consistently expects encryption. Unencrypted portable devices are the leading source of HIPAA enforcement actions.
- ✓ **Audit Controls (Required):** Implement hardware, software, or procedural mechanisms to record and examine activity in systems containing ePHI.
- ✓ **Integrity Controls (Addressable):** Implement mechanisms to authenticate ePHI and ensure it has not been altered or destroyed in an unauthorized manner.
- ✓ **MFA for remote access to ePHI systems:** Not explicitly required by HIPAA but expected by OCR given current threat landscape.

3. Security Risk Analysis as the Foundation

The Security Risk Analysis is the single most important HIPAA Security Rule obligation. It is the first thing OCR requests in any investigation:

- **Scope:** The SRA must cover all ePHI where it is created, received, maintained, or transmitted including all systems, devices, locations, and business associates.
- **Threat Identification:** Identify all reasonably anticipated threats to ePHI confidentiality, integrity, and availability.
- **Vulnerability Assessment:** Identify vulnerabilities in your technical, physical, and administrative controls.
- **Likelihood and Impact:** Rate each identified risk by likelihood of occurrence and potential impact.
- **Risk Register:** Document all identified risks with current control status, residual risk rating, and remediation plan.
- **Update Frequency:** The SRA must be updated when there are changes to operations, technology, or environment, not just annually.

4. Incident Response Under HIPAA

HIPAA requires a documented security incident response plan. The Breach Notification Rule adds time-critical notification obligations:

- **Security Incident Procedures (Required):** Written procedures for identifying, responding to, mitigating, and documenting security incidents.
- **Breach Definition:** Unauthorized acquisition, access, use, or disclosure of unsecured PHI that compromises security or privacy.
- **Notification Timeline:** 60 days from discovery to notify affected individuals, HHS OCR, and media if 500 or more individuals in a state are affected.
- **OCR Reporting:** All breaches affecting 500 or more individuals must notify OCR within 60 days. Smaller breaches are logged and reported annually by March 1.
- **Low Probability Analysis:** If a potential breach occurs, you may conduct a four-factor risk assessment to determine if notification is required. This analysis must be documented.

5. Business Associate Cybersecurity Obligations

Business associates are directly liable under HIPAA. If your organization is a BA, the Security Rule applies to you as fully as to covered entities:

- **Direct Liability:** Since the HITECH Act, BAs are directly subject to HIPAA Security Rule. OCR can investigate and penalize BAs independent of the covered entity.
- **Subcontractor BAs:** If you share ePHI with a subcontractor, that subcontractor is also a BA and must have a BAA in place.
- **BAA Requirements:** Your BAA must include specific security obligations: implement appropriate safeguards, report incidents and breaches, and ensure subcontractors comply.
- **Incident Reporting to Covered Entity:** BAs must report security incidents and breaches to the covered entity without unreasonable delay.

6. HIPAA Cybersecurity Exam Readiness Checklist

Before an OCR audit or investigation, confirm you can produce:

- Current Security Risk Analysis covering all ePHI environments
- Risk management plan with remediation status for identified risks
- Evidence of technical safeguards: encryption configs, access control logs, audit logs
- Security incident response policies and procedures
- Incident log for prior 6 years per HIPAA retention requirement
- Workforce security training records with dates and content
- BAAs with all vendors and subcontractors that access ePHI
- Contingency plan covering backup, disaster recovery, and emergency mode operations

NEXT STEP

Build Your Governance Roadmap

Reading this guide is step one. Step two is knowing exactly where your organization stands and what it takes to close the gaps before a regulator does it for you.

Our assessment delivers a prioritized governance roadmap tailored to your regulatory environment.

WHAT THE ASSESSMENT DELIVERS

- ✓ AI usage discovery across your organization
- ✓ Governance gap analysis by regulatory framework
- ✓ Infrastructure and vendor AI risk review
- ✓ Regulatory exposure analysis (SEC, FINRA, HIPAA)
- ✓ Prioritized governance roadmap
- ✓ Board-ready executive summary
- ✓ Regulatory readiness score by framework

Book Your Assessment →

centience.ai/assessments/healthcare

Call us: (877) 945-7177